Nota de portafolio: este informe es una auditoría real realizada con fines académicos. El nombre del dominio, direcciones IP, nombres de locales y de proveedores externos han sido sustituidos por valores ficticios para proteger la identidad del cliente real, conforme a la confidencialidad profesional y al RGPD. La metodología, los hallazgos, su severidad y las correcciones propuestas son fieles al trabajo original.

CONFIDENCIAL

Auditoría de reconocimiento externo — axezone-demo.com

Informe de ciberseguridad (OSINT / recon pasivo) · Metodología MSA-Recon, basada en PTES, OWASP WSTG y NIST SP 800-115

Objetivo	axezone-demo.com (203.0.113.10 — OVH SAS, AS16276)
Modalidad	Caja negra, reconocimiento pasivo y de huella mínima (sin intrusión)
Fecha de ejecución	01–02/10/2026
Autorización	Autorización verbal del propietario de la web; ampliación puntual a reservaspro-ejemplo.com autorizada por el responsable del ejercicio (ver §9)
Auditores	Xavier Margalef
Versión del documento	2.0
Clasificación	*Informe de muestra de portafolio — datos del cliente real anonimizados; no corresponde a una empresa identificable*

Índice

1. Parte I — Informe ejecutivo
2. Parte II — Informe técnico
    1. Metodología
    2. Arquitectura identificada
    3. Desarrollo del reconocimiento
    4. Hallazgos técnicos
    5. Cobertura y cierre
    6. Decisiones y límites de alcance
3. Anexos: normativa, glosario, referencias

PARTE I — INFORME EJECUTIVO

1. RIESGO GLOBAL Y CONCLUSIÓN

Riesgo global: BAJO-MEDIO**.** No hay vulnerabilidad crítica ni vía de ataque activa confirmada. El riesgo real está en dos áreas de negocio, no en la infraestructura técnica: el uso de cookies de rastreo sin consentimiento previo (confirmado en navegador) y la dependencia de proveedores externos sin contrato de protección de datos (DPA) verificado. Un hallazgo técnico — DNS huérfano en `calendar.axezone-demo.com` — puntúa "Alto" (CVSS 8.2) si llegara a confirmarse una toma de control del subdominio, pero esa confirmación excede lo que permite un recon pasivo; aun así es la corrección más urgente por su bajo coste y alto impacto potencial.

DATO	VALOR
Dominio / IP principal	`axezone-demo.com` → `203.0.113.10` (OVH, Francia)
Hallazgo más grave	`calendar.axezone-demo.com` → `198.51.100.50` (AWS Irlanda), DNS huérfano, puertos 80/443/21/22/8080/8443 todos *filtered*, CVSS 8.2
Infraestructura legacy sin uso	`203.0.113.20` (CDN OVH) — 3 subdominios de ciudad devuelven `520 Domain not allowed on CDN`; `www` funciona bien
Proveedores de reservas (datos de clientes)	ReservaPro/reservaspro-ejemplo.com (`192.0.2.80`, 5 locales) y Proveedor B, EE.UU. (Local 6) — ninguno con DPA verificado
Cookies sin consentimiento	`_fbp` (Meta) y `_ttp` (TikTok), confirmadas en navegador real antes de aceptar el banner

2. HALLAZGOS, RIESGO E IMPACTO NORMATIVO

Cada fila es un hallazgo del ejercicio, identificado como **REC-01 a REC-19** (REC = Reconocimiento, numeración correlativa propia de este informe, en el orden en que se fue documentando — no es un identificador CVE ni un estándar externo). El detalle completo de cada uno, con comandos y evidencia, está en la Parte II, §7.

ID	HALLAZGO	SEVERIDAD	CVSS	IMPACTO SI NO SE CORRIGE	NORMATIVA	ESTADO

REC-15	DNS huérfano, `calendar.axezone-demo.com` → AWS (posible subdomain takeover)	ALTO	8.2	Phishing/daño de marca bajo dominio legítimo si un tercero reclama la IP	RGPD Art. 32/33-34 (si deriva en brecha)	Confirmado hasta el límite del recon pasivo
REC-10 / REC-13	Cookies de rastreo (Meta, TikTok) antes de consentimiento, mismo plugin como causa raíz	MEDIO	N/A	Infracción de consentimiento confirmada en 2 plataformas	LSSI-CE Art. 22 — hasta 150.000€ por cookie, infracción más sancionada por la AEPD	Confirmado en navegador real
REC-09	Dependencia de terceros (ReservaPro, Metricool) sin DPA verificado	MEDIO	N/A	Tratamiento de datos de reserva sin base contractual verificada	RGPD Art. 28 — hasta 10M€ o 2% facturación	Abierto — verificar DPA
REC-12	Proveedor B (Local 6) procesa datos con transferencia a EE.UU. sin garantías verificadas	BAJO / MEDIO	N/A	Fallo de reserva ya confirmado en el Local 6 + transferencia internacional sin cobertura	RGPD Art. 44-49 — mismo techo que REC-09	Confirmado
REC-19	PushOwl (push web), tercero no inventariado, timing de consentimiento sin verificar	BAJO	N/A	Mismo tipo de infracción que REC-10/13 si se confirma el timing	LSSI-CE Art. 22 (pendiente de confirmar)	Identificado
REC-14	Subdominios legacy activos no detectados por M3 (crt.sh), gap de cobertura corregido con fuentes pasivas adicionales	BAJO	N/A	Higiene de DNS — sin impacto en el servicio real (`www` funciona)	—	Corregido
REC-05	Sin HSTS / CSP / X-Frame-Options / X-Content-Type-Options	BAJO-MEDIO	5.4	Downgrade SSL-stripping, clickjacking, MIME-sniffing	RGPD Art. 32 (medidas técnicas)	Abierto

REC-02	`xmlrpc.php` accesible	MEDIO-BAJO	5.3	Fuerza bruta distribuida / amplificación DDoS pingback	ENS op.exp.4	Abierto
REC-01 / REC-06	Versión de PHP/WordPress y plugins expuesta (`X-Powered-By`, `readme.html`, meta generator); cruzado con CVE conocidos — WPML y Site Kit parcheados, Really Simple Security sin versión visible (tuvo CVE crítico 9.8 en 2024)	BAJO	5.3	Si Really Simple Security estuviera en versión vulnerable, bypass de autenticación (CVSS 9.8)	ISO 27001 A.8.8	Abierto
REC-04	DMARC en `p=none`	BAJO-MEDIO	N/A	Dominio suplantable en phishing dirigido	RGPD Art. 32 (si deriva en fraude)	Plan de escalado propuesto
REC-16	Puertos adicionales en el apex (113/135/587/3306), estado inestable entre escaneos	BAJO	N/A	Ninguno confirmado — 3306 nunca respondió como MySQL abierto	—	Cerrado
REC-03 / REC-07 / REC-08 / REC-11 / REC-14b / REC-17 / REC-18	Hosting compartido, puertos protegidos, balanceador OVH, candidato descartado, wildcard descartado, recon del proveedor, UDP — ver informe técnico	INFORMATIVO	N/A	Sin acción requerida	—	Cerrado

3. PRIORIDADES DE CORRECCIÓN

1. **Cookies de marketing sin consentimiento** (REC-10/13) — condicionar al CMP. Mayor riesgo económico inmediato, corrección barata.
2. **DNS huérfano de `calendar.axezone-demo.com`** (REC-15) — borrar o volver a dar de alta el registro. Acción más urgente por riesgo de suplantación.
3. **Contratos DPA** con ReservaPro y Proveedor B (REC-09/12) — confirmar o solicitar.
4. **DNS de los 3 subdominios de ciudad** (REC-14) — dar de baja.

5. **Cabeceras de seguridad HTTP y versiones de software expuestas** (REC-05/01/02/06) — remediación estándar de higiene.

Detalle técnico, comandos y evidencia de cada punto: Parte II. Cuantías de sanción: Anexo A (son techos legales, no una predicción de sanción real).

PARTE II — INFORME TÉCNICO

4. METODOLOGÍA — MSA-RECON

MSA-Recon (Methodology-driven Security Audit) es el protocolo mínimo de reconocimiento usado en este ejercicio: 6 movimientos núcleo, siempre en el mismo orden, cada uno con un único comando de referencia. No se añaden herramientas adicionales salvo que un movimiento dé señal que lo justifique — mantiene el proceso repetible y evita ruido.

#	MOVIMIENTO	PREGUNTA QUE RESPONDE	COMANDO NÚCLEO
M1	Identidad	¿Quién registra esto y hace cuánto?	`whois <dominio>`
M2	Resolución	¿A qué IP resuelve y quién gestiona correo/DNS?	`dig <dominio> A/MX/TXT/NS +short`
M3	Certificados	¿Hay subdominios que nadie mencionó?	`curl crt.sh/?q=%.<dominio>&output=json`
M4	Vecindad	¿Es IP dedicada o compartida?	reverse IP lookup
M5	Huella de app	¿Qué stack corre y qué filtra en cabeceras?	`curl -I -s -L https://<dominio>`
M6	Puertos núcleo	¿Qué más escucha además de 443?	`nmap -sS -sV -Pn -p 80,443,21,22,8080,8443 <ip>`

Dos principios transversales: *Sigilo* — todo M1-M6 es pasivo o de huella mínima, sin escaneos agresivos ni fuzzing salvo justificación puntual. *Trazabilidad* — ningún dato se documenta sin decir de dónde sale y con qué otro dato se conecta; un hallazgo no se cierra hasta tener evidencia directa, no solo una coincidencia (así se trató la relación axezone-demo.com/reservaspro-ejemplo.com, confirmada solo tras verla en código y en el diagrama de arquitectura a la vez).

5. ARQUITECTURA IDENTIFICADA



Diagrama construido a partir de la evidencia documentada en el inventario de §5.1 (whois, `dig`, `curl`, `nmap` y crt.sh/dnsdumpster/hackertarget) — no es un esquema teórico, cada nodo y relación tiene su comando y resultado trazables. Se omiten por claridad los activos sin hallazgo asociado (`www.axezone-demo.com`, que resuelve correctamente en la misma IP legacy; Google Tag Assistant; los dos candidatos descartados, `dominio-candidato-ejemplo.com` y `vecino-hosting-ejemplo.es`) — están todos en la tabla de §5.1. Un único WordPress sirve a 6 locales y delega reservas a dos proveedores distintos — esa falta de uniformidad es la causa confirmada del fallo de reserva en el Local 6 (REC-12).

5.1 Inventario de activos, dominios e IPs

Todos los dominios, subdominios e IPs que han aparecido durante el recon, con su relación con el objetivo y la evidencia que la sostiene — es la tabla que conecta los hallazgos individuales entre sí en vez de dejarlos como piezas sueltas.

ACTIVO	TIPO / RELACIÓN	EVIDENCIA DE LA RELACIÓN	DATOS QUE MANEJA	CRITICIDAD	REF.
`axezone-demo.com` `203.0.113.10`	Infraestructura propia (apex)	M1/M2 — whois OVH SAS, `dig A`	CMS WordPress; sin PII directa (reservas delegadas a terceros)	**ALTA** — núcleo del negocio digital	REC-01…08, 16, 18

`www.axezone-demo.com` → `203.0.113.20`	Alias del apex, en IP legacy/CDN	`dig A` + `curl -IL`: 301→301→200, cadena correcta	Sirve la web real; sin PII propia	**BAJA**	REC-14
3 subdominios de ciudad (*.axezone-demo.com) → `203.0.113.20`	Infraestructura propia huérfana (parcial)	dnsdumpster + hackertarget; `curl -I` → 520 CDN	Ninguno activo — CDN rechaza el hostname	**BAJA** — higiene de DNS	REC-14, REC-14b
`calendar.axezone-demo.com` → `198.51.100.50`	Infraestructura propia huérfana	`dig A` + whois AWS; `nmap` 6 puertos filtered	Desconocido — sin servicio respondiendo	**MEDIA-ALTA** — CVSS 8.2 si se confirma huérfano	REC-15
`reservaspro-ejemplo.com` / `calendar.*` `192.0.2.80`	Proveedor de reservas SaaS (ReservaPro) — tercero, autorizado por el tutor para recon	`grep` código fuente + M1-M6 completo (REC-17)	**PII de clientes**: nombre, email, teléfono (5 de 6 locales)	**ALTA** — procesa datos de clientes finales	REC-09, REC-11, REC-17
`proveedorb-ejemplo.com`	Proveedor de reservas SaaS — tercero, grupo internacional de reservas (EE.UU.)	`grep` de código en la página del Local 6	**PII de clientes** del Local 6 + transferencia internacional	**ALTA** — PII + transferencia fuera UE	REC-12
Metricool, Meta Pixel, TikTok Pixel, Google Tag Assistant, PushOwl	Terceros de analítica/marketing — scripts de cliente	DevTools (Network, Application → Cookies/Local Storage)	Cookies e identificadores de tracking	**MEDIA** — infracción confirmada en 2 de 5 (REC-10/13)	REC-09, REC-10, REC-13, REC-19
`dominio-candidato-ejemplo.com`	Candidato investigado y descartado	whois/dig/crt.sh /grep — ningún dato coincide con el objetivo	N/A — sin vínculo técnico	**N/A** — cerrado	REC-11
`vecino-hosting-ejemplo.es`	Vecino de hosting de reservaspro-ejemplo.com, sin relación con el objetivo	M4 reverse IP sobre 192.0.2.80	N/A — solo evidencia de multi-tenencia	**N/A** — no es activo del objetivo	REC-17

6. DESARROLLO DEL RECONOCIMIENTO

M1-M6 sobre el objetivo no dieron sorpresas por sí solos: OVH como registrador y hosting (M1/M2), IP compartida con cientos de dominios ajenos (M4), Apache+PHP 8.3+WordPress (M5), y en M6 dos puertos sin identificar (8080/8443) más un FTP atípico. Se cerraron con comandos igualmente pasivos: 21 y 8080 completan el handshake TCP pero no entregan banner — `tcpwrapped`, puerto protegido, no servicio roto (REC-07); y el servidor que respondía (OpenResty) era el balanceador IPLB de OVH, con Apache real detrás (REC-08).

El encargo solo daba el dominio y una pista oral: "gestor reservapro". Localizar la integración llevó pasos en falso que se documentan por ser parte del método: un dominio de memoria sin verificar, descartado por falta de evidencia; dos candidatos plausibles entre los dominios externos de la home (`fh-kit.com`, `cdn.landbot.io`) resultaron ser un kit de botones y un chatbot. Un `grep -i "reservapro"` sobre la home no dio nada; repetido sobre una página de ubicación (`/ubicacion/local-1/`) sí reveló `reservaspro-ejemplo.com` — el dato vivía en la página de local, no en la home. `whois` / `dig` confirmaron 192.0.2.80 (Arsys/IONOS), sin relación de infraestructura con OVH salvo la integración funcional (REC-09).

Más adelante se confirmó que `dominio-candidato-ejemplo.com` existe de verdad y coincide en hosting (IONOS) con reservaspro-ejemplo.com — duda razonable de si era el mismo proveedor. Registrador, nameservers, IP, ASN y referencias en código no coinciden en nada salvo el hosting compartido: insuficiente para establecer relación (REC-11). Confirmar negativos es tan parte del método como confirmar positivos.

Probando el sitio como usuario real se obtuvieron dos hallazgos que ningún comando habría dado por sí solo: "Powered by ReservaPro" visible en el Local 4 (confirma REC-09, invisible por curl porque lo pinta JavaScript en runtime) y un error real al reservar en el Local 6. Repetir el `grep` de ReservaPro sobre la página del Local 6 dio vacío; sin filtrar apareció Proveedor B en su lugar (REC-12) — se completó entonces la tabla de los 6 locales en vez de asumir homogeneidad.

Con DevTools en incógnito, sin tocar el banner de consentimiento, se amplió el inventario de terceros del lado del cliente: TikTok Pixel y Google Tag Assistant (REC-13), y luego PushOwl en Local Storage (REC-19). La cookie `_fbp` de Meta ya se había visto por curl, pero solo se dio por confirmada al cruzarla con la sesión de navegador real. Repitiendo `curl -IL` sobre toda la redirección, desde otra máquina, se vio `set-cookie: _fbp` con un valor nuevo en cada salto — fija el mecanismo real como la cabecera HTTP del servidor (plugin PixelYourSite), no solo JavaScript, misma causa raíz para TikTok vía `last_pys_landing_page`.

M3 (crt.sh) solo devolvió el apex en la primera pasada. Cruzando dos fuentes pasivas adicionales (dnsdumpster + hackertarget) aparecieron 3 alias de ciudad en una IP legacy de OVH que el CDN rechaza (520), y que `www` resuelve a esa misma IP legacy — la hipótesis de que repetía el problema no se sostuvo:

`www` redirige correctamente porque sí sigue dado de alta (REC-14). El mismo patrón, a nivel de recurso cloud, apareció en `calendar.axezone-demo.com` → AWS Irlanda, sin servicio respondiendo en ningún puerto; sin poder distinguir por recon pasivo si está dado de baja o solo firewalled, se documenta la ambigüedad (REC-15).

Por instrucción explícita del responsable del ejercicio, se amplió el alcance a reservaspro-ejemplo.com — fuera de eso no se investiga infraestructura de terceros sin autorización expresa. M1-M6 sobre el proveedor confirmó hosting compartido Plesk (`vecino-hosting-ejemplo.es` ajeno en la misma IP) y descartó, tras verificación directa, una huella heurística de nmap (Go-IPFS/InfluxDB): la respuesta real es un 404 mínimo correctamente configurado (REC-17). Solo M3 quedó sin resolver: crt.sh devolvió `502 Bad Gateway` en dos intentos reales — incidencia del servicio, no de la metodología.

Desde una máquina con salida de red directa se amplió el escaneo del apex más allá de M6 (top-1000), encontrando 4 puertos adicionales. Repetido 4 veces, el estado de 113/135/3306 fluctúa entre escaneos — hipótesis: un escaneo más agresivo activa más bloqueo (posible IDS/IPS). En los cuatro, 3306 nunca respondió como MySQL real, solo `tcpwrapped` o `filtered` (REC-16). Desde la misma máquina se completó un escaneo UDP real (top-20 y top-200): todos los puertos `open|filtered`, sin poder confirmar ni descartar servicios reales (REC-18). Un primer intento de UDP lanzado desde el propio entorno de trabajo se descartó: dio la misma huella contra IPs distintas y contra una IP de prueba no enrutable (TEST-NET-3), confirmando que esa salida de red está interceptada.

7. HALLAZGOS TÉCNICOS

CVSS 3.1 cuando aplica. La columna "Severidad" de la Parte I es una valoración contextual del equipo: en fugas de información puras sin vector de explotación demostrado (REC-01/02/05/06) se etiquetan por debajo de su rango CVSS oficial porque no se verificó ningún paso adicional que las convierta en acceso real.

REC-15 · DNS huérfano en calendar.axezone-demo.com → AWS Irlanda

ALTO CWE-706 · CVSS 3.1: **8.2** (`AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:H/A:N`)

Evidencia: `dig calendar.axezone-demo.com A +short` → `198.51.100.50`, whois confirma Amazon (AWS, eu-west-1). `curl -I` en 80 y 443 → timeout. `nmap -sS -sV -Pn -p 80,443,21,22,8080,8443` → los 6 puertos *filtered*, sin fingerprint de servicio.

```
$ dig calendar.axezone-demo.com A +short
198.51.100.50

$ whois 198.51.100.50 | grep -iE "orgname|netname|country"
OrgName:    Amazon Technologies Inc.
NetName:    AT-88-Z
Country:    US  (región de servicio: eu-west-1, Irlanda)

$ curl -I --connect-timeout 5 https://calendar.axezone-demo.com
curl: (28) Connection timed out after 5000 milliseconds

$ nmap -sS -sV -Pn -p 80,443,21,22,8080,8443 198.51.100.50
PORT     STATE    SERVICE
21/tcp   filtered ftp
22/tcp   filtered ssh
80/tcp   filtered http
443/tcp  filtered https
8080/tcp filtered http-proxy
8443/tcp filtered https-alt
```

Interpretación: "filtered" en los 6 puertos es compatible con dos escenarios que el recon pasivo no distingue: un recurso realmente huérfano (el borde de AWS descarta tráfico a una IP no asignada) o un recurso activo detrás de un security group nuevo que bloquea todo por defecto. Confirmarlo exigiría intentar reclamar la IP — fuera del alcance autorizado. En cualquier caso, el registro DNS sigue invitando a un cliente a conectarse a algo que no responde: higiene de DNS confirmada como mínimo.

Riesgo: si se confirmara el takeover (por el propietario, no por este equipo), un atacante podría servir contenido falso con apariencia legítima bajo el dominio — phishing, robo de credenciales, daño reputacional.

Remediación: el propietario debe eliminar el registro DNS si el servicio ya no existe, o reprovisionar el recurso en AWS. Acción de higiene de DNS más urgente del informe.

REC-10 / REC-13 · Cookies de rastreo antes de consentimiento (Meta, TikTok)

MEDIO · CVSS no aplica (cumplimiento, no vulnerabilidad técnica) — LSSI-CE Art. 22

Evidencia: `curl -I -s -L https://axezone-demo.com` ya muestra `set-cookie: _fbp=...` en la primera respuesta del servidor. Confirmado en navegador real (incógnito, sin tocar el banner): `_fbp` y `_ttp` presentes en Application → Cookies. Dos trazas de `curl -IL` independientes, desde máquinas distintas, muestran `set-cookie: _fbp` con un valor nuevo en **cada** salto de la redirección (301→301→200) — el mecanismo es la cabecera HTTP del servidor (plugin PixelYourSite), no solo JavaScript del píxel. La cookie `last_pys_landing_page`, encontrada junto a `_ttp`, conecta ambos hallazgos a la misma causa raíz.

```
$ curl -IL www.axezone-demo.com
HTTP/1.1 301 Moved Permanently          (http → https)
set-cookie: _fbp=fb.1.1790847072497.508271741; domain=axezone-demo.com; Secure

HTTP/2 301                              (www → apex)
set-cookie: _fbp=fb.1.1790847072611.1258260755; domain=axezone-demo.com; Secure

HTTP/2 200                              (respuesta final)
set-cookie: _fbp=fb.1.1790847072743.911259073; domain=axezone-demo.com; Secure
content-type: text/html; charset=UTF-8
```

Application → Cookies (navegador, sin tocar el banner de consentimiento): `_fbp` (dominio `.axezone-demo.com`) y `_ttp` (dominio `.tiktok.com`) presentes; `analytics.tiktok.com/i18n/pixel/events.js` cargado 2 veces en Network antes de interactuar con el banner.

Riesgo: cookies de marketing sin base de consentimiento válida — la infracción que la AEPD sanciona con más frecuencia en España.

Remediación: configurar el CMP o el propio plugin para condicionar la emisión de `Set-Cookie` a la aceptación previa de la categoría "marketing/publicidad".

REC-09 · Dependencia de ReservaPro/reservaspro-ejemplo.com y Metricool

MEDIO (CUMPLIMIENTO) · RGPD Art. 28

Evidencia: comentario de desarrollo sin minificar en el HTML; `data-integration-reservapro-url=https://local1.reservaspro-ejemplo.com` en páginas de ubicación; widget servido desde `calendar.reservaspro-ejemplo.com`, con Stripe.js cargado junto al checkout. `reservaspro-ejemplo.com` y sus subdominios de cliente resuelven a `192.0.2.80` (Arsys/IONOS, AS8560) — proveedor sin relación de infraestructura con OVH. Los 5 locales que usan ReservaPro están mapeados por UUID y subdominio propio en la plataforma del proveedor.

```
$ curl -s https://axezone-demo.com/ubicacion/local-1/ | grep -i "reservapro-"
data-integration-reservapro-url="https://local1.reservaspro-ejemplo.com"

$ dig calendar.reservaspro-ejemplo.com A +short
192.0.2.80

$ whois 192.0.2.80 | grep -iE "netname|org"
NetName:   AS8560 (ahora IONOS SE, antes Arsys)
```

LOCAL	UUID RESERVAPRO	SUBDOMINIO DE RESERVAS
Local 1 (Madrid)	—	`local1.reservaspro-ejemplo.com`
Local 2 (Madrid)	—	`local2.reservaspro-ejemplo.com`
Local 3 (Madrid)	—	`local3.reservaspro-ejemplo.com` (orden invertido)
Local 4 (Valencia)	`00000000-0000-4000-8000-000000000000`	`local4.reservaspro-ejemplo.com`
Local 5 (Murcia)	—	`local5.reservaspro-ejemplo.com`
Local 6 (Tarragona)	Sin integración ReservaPro — usa Proveedor B, ver REC-12	

Riesgo: cadena de suministro — un fallo del proveedor afecta a axezone-demo.com igual que si fuera propio; todos los clientes del proveedor comparten un único host (punto único de fallo fuera del control del cliente auditado).

Dato positivo (indicio, no confirmación): la presencia de Stripe.js sugiere tokenización del pago en el cliente — los datos de tarjeta no tocarían el servidor — pero no se interceptó el flujo real de pago para confirmarlo.

Remediación: limpiar comentarios de desarrollo; formalizar DPA con ReservaPro y Metricool (RGPD Art. 28).

REC-12 · Fragmentación de proveedores: ReservaPro vs Proveedor B (Local 6)

BAJO (DISPONIBILIDAD) / MEDIO (CUMPLIMIENTO)

Evidencia: `grep -i "reservapro-uuid\|reservapro-url"` sobre la página del Local 6 no devuelve nada; el HTML contiene en su lugar `<!-- Proveedor B plugin activated -->` y su script de embed.

Interpretación: El Local 6 usa Proveedor B (grupo internacional de reservas, EE.UU.) en vez de ReservaPro. Hipótesis razonable de migración incompleta a partir del patrón (5 de 6 locales ya en ReservaPro) — sin fecha confirmada, no es un hecho fechado.

Riesgo: (a) disponibilidad — reservas perdidas en el Local 6, ya confirmado; (b) transferencia internacional de datos a EE.UU. sin DPA ni garantías verificadas (RGPD Art. 44-49, mismo techo de sanción que REC-09); (c) gestión de configuración manual e inconsistente por local.

Remediación: completar la migración a ReservaPro o revertir conscientemente; si Proveedor B sigue activo, exigirle DPA/garantías de transferencia internacional.

REC-14 · Subdominios legacy no detectados por M3

BAJO CWE-200 · Gap de cobertura de M3, corregido

Evidencia: dnsdumpster + hackertarget (segunda fuente) revelan 3 subdominios de ciudad en `203.0.113.20`: `curl -I` devuelve `HTTP/1.1 520 Domain not allowed on CDN` (Varnish, OVH) en los tres. `www.axezone-demo.com` resuelve a la misma IP pero `curl -IL` muestra una cadena correcta 301 → 301 → 200 — ese hostname sí está dado de alta en el CDN.

```
$ curl -I https://local-ejemplo.axezone-demo.com
HTTP/1.1 520 Domain not allowed on CDN
server: Varnish
x-cdn-pop: rbx

$ curl -IL www.axezone-demo.com
HTTP/1.1 301 Moved Permanently      (http → https)
HTTP/2 301                          (www → apex)
HTTP/2 200                          (OK — web real, server: Apache)
```

Riesgo: higiene de DNS en los 3 subdominios de ciudad; sin impacto en la experiencia real del cliente (verificado expresamente para `www`).

Remediación: dar de baja el DNS de los 3 subdominios; para `www`, reapuntar directamente al apex actual por higiene (no hay urgencia funcional). A partir de ahora, M3 se complementa siempre con al menos dos fuentes pasivas distintas.

REC-19 · PushOwl — tercero no inventariado

INFORMATIVO · LSSI-CE Art. 22 si se confirma el timing

Evidencia: `localStorage` contiene `pushowl_visitor_token` (UUID de visitante persistente) en la misma sesión de incógnito usada para REC-10/13, sin tocar el banner de consentimiento.

Riesgo: un identificador persistente en localStorage es funcionalmente una cookie de tracking a efectos de LSSI-CE Art. 22. A diferencia de REC-10/13, aquí no se capturó explícitamente el timing antes/después del banner.

Remediación: añadir al inventario de terceros con su DPA; verificar el timing de consentimiento con el mismo método usado en REC-10/13.

REC-05 · Sin cabeceras de seguridad HTTP

BAJO-MEDIO CWE-693 · CVSS 3.1: **5.4** (`AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N`)

Evidencia: ausentes `Strict-Transport-Security`, `Content-Security-Policy`, `X-Frame-Options`, `X-Content-Type-Options`. El certificado TLS es correcto (SAN solo cubre el apex, sin wildcard). `curl -I -X OPTIONS` no distingue el método de un GET normal.

Riesgo: downgrade a HTTP en la primera visita, clickjacking, MIME-sniffing indebido.

Remediación: añadir las cuatro cabeceras a nivel de servidor o vía plugin de seguridad WordPress.

REC-02 · xmlrpc.php accesible

MEDIO-BAJO CWE-16 · CVSS 3.1: **5.3** (`AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L`)

Evidencia: cabecera `X-Pingback` apunta a `/xmlrpc.php`.

Riesgo: vector de fuerza bruta distribuida y amplificación pingback DDoS.

Remediación: deshabilitar si no hay integraciones que lo requieran, o restringir por IP/WAF.

REC-01 · Fuga de versión PHP/CMS

BAJO CWE-200 · CVSS 3.1: **5.3** (`AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N`)

Evidencia: `X-Powered-By: PHP/8.3`; `wp-json` + `X-Pingback` → WordPress.

Remediación: `expose_php = Off`; `ServerTokens Prod`; ocultar versión de WP.

REC-06 · readme.html y meta generator exponen versiones de plugins

BAJO CWE-200 · CVSS 3.1: **5.3**

Evidencia: `/readme.html` accesible; meta generator revela WPML 4.9.7 y Site Kit 1.188.0; Yoast, Contact Form 7 y Really Simple Security confirmados por otras vías (sin versión visible para estos tres).

Cruce con CVE conocidos (NVD/Wordfence/Patchstack, consulta pasiva de versión frente a dato público — no explotación):

PLUGIN	VERSIÓN	CVE DE REFERENCIA	RESULTADO
WPML	4.9.7	CVE-2024-6386 (RCE vía SSTI, CVSS 9.9, afecta ≤4.6.12)	No vulnerable — versión muy por encima del parche (4.6.13)
Site Kit by Google	1.188.0	CVE-2026-62139 (CSRF, CVSS 4.3, afecta ≤1.186.0)	No vulnerable — parcheado en 1.187.0
Really Simple Security	No confirmada	CVE-2024-10924 (bypass de autenticación con 2FA activo, CVSS 9.8 crítico, afecta 9.0.0-9.1.1.1)	No se puede descartar — sin visibilidad de versión no es posible confirmar ni excluir exposición a este CVE crítico

Remediación: eliminar/bloquear `readme.html`; suprimir meta generator; mantener plugins actualizados. Prioritario: confirmar versión real de Really Simple Security (acceso autorizado al admin o fingerprint adicional) dado el antecedente crítico del plugin.

REC-04 · DMARC en modo observación (p=none)

BAJO-MEDIO

Evidencia: `_dmarc.axezone-demo.com TXT` → `v=DMARC1; p=none; rua=mailto:rua@dmarc-ejemplo.com`.

Riesgo: `p=none` solo reporta, no bloquea correo que falle SPF/DKIM — el dominio sigue siendo suplantable.

Remediación: monitorizar los reportes RUA y escalar a `p=quarantine` y luego `p=reject`.

REC-16 · Puertos adicionales en el apex (113/135/587/3306)

BAJO CWE-200 · 4 escaneos independientes

Evidencia: escaneo top-1000 inicial encuentra 4 puertos fuera del set M6. Confirmación dirigida (`-sV`) y dos repeticiones más muestran que el estado de 113/135/3306 fluctúa entre escaneos (hipótesis razonable del equipo: interferencia de IDS/IPS según la agresividad del escaneo). En los 4 escaneos, 3306 nunca respondió como un MySQL real abierto — solo `tcpwrapped` o `filtered`.

Remediación: cerrar 113 si no está en uso; nada que remediar en 587 (correo esperado) ni en 3306 (protegido en los 4 escaneos); monitorizar 135.

Hallazgos cerrados sin remediación pendiente

REC-03 — hosting compartido sin IP dedicada (cientos de dominios ajenos en 203.0.113.10); riesgo de vecindad aceptado, sin acción obligatoria. **REC-07** — puertos 21/8080 con TCP completo pero sin respuesta de aplicación (`tcpwrapped`): comportamiento esperado de un puerto protegido. **REC-08** — el servidor OpenResty visto en M5 es el balanceador IPLB de OVH, con Apache real detrás; el puerto 80 ya redirige a HTTPS vía Really Simple Security (pero sin HSTS posterior, ver REC-05). **REC-11** — `dominio-candidato-ejemplo.com` investigado (whois, dig, crt.sh, grep del código) y descartado: ningún dato técnico lo vincula a axezone-demo.com. **REC-14b** — el subdominio con errata "origial" no es un wildcard (un nombre aleatorio no resuelve), es un registro real y distinto. **REC-17** — M1-M6 sobre reservaspro-ejemplo.com cerrado salvo M3 (crt.sh devolvió 502 en dos intentos reales, incidencia del servicio); confirma hosting Plesk compartido con un dominio ajeno (`vecino-hosting-ejemplo.es`). **REC-18** — escaneo UDP real (top-20 y top-200) sobre el apex: todos los puertos `open|filtered`, sin poder confirmar ni descartar servicios UDP reales; cerrado como intento documentado.

8. COBERTURA Y CIERRE

PUNTO	ESTADO	RESULTADO
M1-M6 sobre el objetivo	HECHO	OVH SAS, creado 2018-01-09 · A: 203.0.113.10 · MX: mx1-3.mail.ovh.net, SPF sin DMARC propio en primera pasada (luego confirmado p=none) · vecindad: cientos de dominios ajenos · Apache+PHP 8.3+WordPress · puertos: 21 open/tcpwrapped, 22 filtered, 80/443 open (OpenResty→Apache), 8080/8443 open/tcpwrapped

Checks de cierre (FTP, 8080/8443, Apache vs OpenResty, forzado HTTPS)	**RESUELTO**	Los 4 puntos abiertos por el escaneo de puertos quedan explicados → REC-07/REC-08
M1-M6 sobre reservaspro-ejemplo.com (autorizado por el tutor)	**CERRADO SALVO M3**	→ REC-17
Ampliación top-1000 + UDP sobre el apex	**HECHO**	→ REC-16, REC-18
Cobertura DNS cruzada (dnsdumpster + hackertarget)	**HECHO**	→ REC-14, REC-14b, REC-15
DevTools / navegador real (cookies, consentimiento)	**HECHO**	→ REC-09, REC-10, REC-13, REC-19

Único cabo suelto del documento: el timing exacto de consentimiento de PushOwl (REC-19) — ver prioridades en la Parte I.

9. DECISIONES Y LÍMITES DE ALCANCE

- **Por qué no se fue más allá del recon:** el alcance autorizado cubre solo reconocimiento pasivo y activo mínimo (M1-M6 + cierre). Enumerar usuarios de WordPress, intentar login o explotar un plugin desactualizado exigiría autorización explícita adicional.
- **Infraestructura de terceros:** el alcance autorizado cubre por defecto únicamente axezone-demo.com. La ampliación a reservaspro-ejemplo.com (192.0.2.80) se realizó bajo instrucción expresa del responsable del ejercicio, documentada con carácter previo y sujeta a los mismos principios de sigilo y reconocimiento sin intrusión que rigen el resto del trabajo. Proveedor B y Metricool no cuentan con autorización equivalente y permanecen fuera de cualquier actividad activa.
- **Escaneo UDP descartado desde el propio entorno de trabajo:** un intento inicial devolvió la misma huella idéntica contra dos IPs distintas y contra una IP de prueba no enrutable (TEST-NET-3, RFC 5737) — confirma que la salida de red de ese entorno está interceptada/proxificada, así que no se documentó como hallazgo. La fuente válida fue una máquina con salida de red directa (REC-18).

- **Qué haría falta con autorización adicional:** confirmar la versión real de Really Simple Security (sin versión visible por vía pasiva — ver REC-06, CVE-2024-10924 crítico pendiente de descartar), enumeración de usuarios WordPress, e interceptar el flujo real de pago para confirmar el alcance de PCI-DSS (hoy solo hay un indicio por la presencia de Stripe.js, REC-09).

ANEXOS

A. MARCO NORMATIVO APLICABLE

ESTÁNDAR / NORMA	CÓMO APLICA AQUÍ
RGPD + LOPDGDD	Art. 5.1.f y 32 — medidas técnicas (REC-01/02/05/06); Art. 28 — ReservaPro y Metricool como encargados de tratamiento (REC-09); Art. 44-49 — transferencia internacional vía Proveedor B (REC-12); Art. 33/34 — notificación de brecha en 72h si deriva en incidente. Autoridad competente: AEPD. Sanciones hasta 10M€ o 2% de facturación anual (techo legal, no predicción de sanción real).
LSSI-CE (Ley 34/2002)	Art. 22 — consentimiento previo para cookies no esenciales. Confirmado para Meta (REC-10) y TikTok (REC-13); PushOwl pendiente de confirmar (REC-19). Sanción hasta 150.000€ por cookie — la infracción más sancionada por la AEPD.
ISO/IEC 27001:2022 (Anexo A)	A.8.8 gestión de vulnerabilidades (REC-01/02/06); A.8.9 gestión de configuración (REC-05); A.5.19-5.22 relaciones con proveedores (REC-09); A.8.24 criptografía (TLS).
ENS (RD 311/2022) + guías CCN-STIC	op.exp.4 mantenimiento de software; mp.com.2 confidencialidad en comunicaciones; op.ext recursos externos. Voluntario para una empresa privada, exigible si presta servicio a sector público.
MAGERIT v3	Amenazas: E.19 fuga de información, E.21 falta de mantenimiento, A.5 suplantación de identidad, A.11 acceso no autorizado. Impacto medio, probabilidad media-baja con el nivel de exposición encontrado.
NIS2 (UE 2022/2555)	No aplica por tamaño a un negocio de 6 locales salvo que supere los umbrales de mediana empresa; se cita como marco de tendencia, especialmente en gestión de riesgo de cadena de suministro (REC-09).
Metodología de referencia	M1-M2/M6 se alinean con PTES (Footprinting) y NIST SP 800-115 (Discovery); M5/M6 con OWASP WSTG-INFO-02/08/09. MITRE ATT&CK: TA0043 Reconnaissance — T1590 (M1/M2), T1596 (M3), T1592 (M5), T1595 (M6), T1591 (ubicaciones y terceros).

Esta sección es orientativa, con fines formativos y de GRC — no constituye asesoramiento legal.

B. GLOSARIO

TÉRMINO	SIGNIFICADO
REC-XX	Identificador correlativo de cada hallazgo de este informe (Reconocimiento nº XX). Numeración propia del ejercicio, no un estándar externo
ASN	Autonomous System Number — identificador de la red/proveedor que anuncia un rango de IPs
CT log	Certificate Transparency log — registro público de certificados TLS, usado para descubrir subdominios
CVSS	Common Vulnerability Scoring System — puntuación de severidad de vulnerabilidades (0-10)
CWE	Common Weakness Enumeration — catálogo de tipos de debilidad de software
DNS huérfano (dangling DNS)	Registro DNS que apunta a un recurso ya dado de baja — riesgo si un tercero puede reclamarlo
DMARC	Política anti-suplantación de correo
DPA	Data Processing Agreement — contrato de encargado de tratamiento (RGPD Art. 28)
HSTS	Cabecera que obliga al navegador a usar siempre HTTPS con ese dominio
Subdomain takeover	Toma de control de un subdominio aprovechando un DNS huérfano que apunta a un recurso cloud liberado
tcpwrapped	Handshake TCP completo sin respuesta de la aplicación — típico de un puerto protegido por ACL

C. REFERENCIAS

- PTES — Penetration Testing Execution Standard
- OWASP Web Security Testing Guide (WSTG) v4.2 y OWASP Top 10:2021
- MITRE ATT&CK — Enterprise Matrix, TA0043 Reconnaissance
- FIRST — CVSS v3.1 Specification Document
- ISO/IEC 27001:2022 — Anexo A
- Real Decreto 311/2022 (Esquema Nacional de Seguridad) y guías CCN-STIC
- MAGERIT v3 (Ministerio de Hacienda y Función Pública)
- Reglamento (UE) 2016/679 (RGPD); LO 3/2018 (LOPDGDD); Ley 34/2002 (LSSI-CE)
- Directiva (UE) 2022/2555 (NIS2)

- Agencia Española de Protección de Datos (AEPD) — guías y resoluciones sobre cookies

Informe formativo de reconocimiento (recon/OSINT) sobre un dominio real, con fines académicos. Las referencias a sanciones son orientativas y no constituyen asesoramiento legal.